

감사결과 처분요구서

- 사내 전산시스템 보안관리 실태 감사 -

2025. 1.

한국수력원자력(주) 상임감사위원

목 차

I . 감사 실시 개요	1
1. 감사 배경 및 목적	1
2. 감사 중점 및 대상	1
3. 감사 실시 과정	2
4. 감사 결과 처리	2
II . 감사결과 처분요구와 통보	3
1. 처분요구 및 통보 사항 일람표	3
2. 처분요구 및 통보 사항 명세	3
(1) 접속기록 관리 미흡	4
(2) 세부적인 작업 내용 기록 미흡	6
(3) 개인정보 관련 지침서 내용 오류	9

I . 감사 실시 개요

1. 감사 배경 및 목적

■■■, ■■■ 등 주요 전산시스템의 보안 신뢰성, 관리 투명성, 개발자 및 협력 회사에 대한 보안관리 적절성, 사내 전산망 보안시스템 취약성을 점검하고자 이번 감사를 실시하였다.

2. 감사 중점 및 대상

이번 감사는 ○○본부 □처에서 담당하는 ■■■시스템 및 ○○본부 ▢센터에서 담당하는 ◆◆시스템의 유지보수 관련 보안관리 적절성과 사내 전산망 보안시스템의 취약성을 점검하여 개선 사항을 도출하는 데 중점을 두었다.

▢센터에서는 우리 회사 「정보보안업무 세부운용지침」 제11조에 따라 정보보안업무 및 활동을 조사·점검하기 위하여 연 1회 이상 정보보안감사를 실시하고 있으므로, 이번 감사는 관련부서와 협의하여 정보보안감사와 중복되지 않는 범위에서 실지감사를 실시하였다.

3. 감사 실시 과정

이번 감사는 2024. 11. 18.부터 같은 해 11. 22.까지 감사실 조사부 검사역 2명을 투입하여 사실관계 확인 및 자료 조사 등을 통하여 관련 규정의 위반 여부를 조사하였다.

이번 감사를 위하여 관련 규정, 유지보수 인력의 사내 전산시스템 접속기록 등의 자료를 수집하여 분석하였고, IT분야 사내 전문가와 협업하여 감사를 실시하였다.

4. 감사 결과 처리

2025. 1. 13. 피감부서(이하 “관련부서”라 한다)인 □처 및 ▢센터의 업무 관련자가 참석한 가운데 감사 마감회의를 하여 주요 지적사항에 대한 의견을 교환하였고, 감사실 내부 검토과정을 거쳐 2025. 1. 15. 상임감사위원의 결재로 감사 결과를 확정하였다.

II. 감사결과 처분요구와 통보

1. 처분요구 및 통보 사항 일람표

(단위: 건, 명, 백만 원)

일련 번호	관련부서	구분	처분요구 등 종류	제 목	건, 금액 (인원)
1	□처	특정	통보	접속기록 관리 미흡	1
2	回센터	특정	통보	세부적인 작업 내용 기록 미흡	1
3	回센터	특정	통보	개인정보 관련 지침서 내용 오류	1

2. 처분요구 및 통보 사항 명세: 별첨

한국수력원자력(주) 상임감사위원

통 보

제 목 접속기록 관리 미흡

관 련 부 서 ○○본부 □처

조 치 부 서 ○○본부 □처

내 용

1. 업무 개요

○○본부 □처는 정보화 종합계획 수립 및 총괄, 정보시스템 설계·운영·유지보수·개발·교육 등의 업무를 담당하고 있다.

2. 관계 법령 및 판단기준

우리 회사 「정보보안업무 세부운용지침」 제52조에는 정보시스템 관리책임자는 정보시스템의 유지보수와 관련한 절차, 주기, 문서화 등과 관련한 사항을 자체 내규(또는 지침 등)에 포함하여야 하고, 예방 및 유지보수에 대한 기록 유지, 작업 수행 내용 기록 유지 등을 고려하여야 한다고 명시되어 있다.

우리 회사 “❖❖❖❖(▼▼ 보안관리 지침)” ㉠항에 따르면 사업자에게 제공된 전산망 접근기록을 확인할 수 있도록 작업 로그를 1년 이상 저장하여야 한다.

3. 접속기록 관리 미흡

□처에서는 관련 지침에 따라 우리 회사 ■■■시스템의 유지보수 인력에게 제공된 전산망 접속기록을 1년 이상 보관하고 있었는데, 최근 1년간(2023. 11. 1.~ 2024. 10. 31.) ■■■시스템 유지보수 인력의 내부망 및 외부망 접속기록 중 접속 IP주소를 확인한 결과, 유지보수 인력에게 할당된 IP주소가 아닌 “127.0.0.1”(내부망 □건)과 “0:0:0:0:0:0:1”(내부망 ■건, 외부망 ◆건)의 접속기록이 확인되었다.

“127.0.0.1”은 현재 기기 IP주소의 IPv4 체계, “0:0:0:0:0:0:1”은 현재 기기 IP주소의 IPv6 체계로서 기기 자체에서만 사용할 수 있는 IP주소로 확인되었는데, 우리 회사의 네트워크는 물리적으로 내·외부망이 분리되어 있음에 따라 보안상 문제는 없지만, 유지보수 인력 접속기록의 철저한 관리를 위하여 현재 기기를 의미하는 IP주소가 아닌 할당된 IP주소로 기록될 수 있도록 개선이 필요하다.

관련부서 의견 관련부서는 감사 결과를 수용하면서 개발 작업 등 수행 후 테스트 중의 기록으로 보안상 문제는 없지만, 현재 기기를 의미하는 IP주소가 접속 주체에 대한 추적성이 떨어질 수 있으므로 접속자에게 할당된 IP주소로 기록될 수 있도록 개선하겠다는 의견을 제시하였다.

조치할 사항 □처장은 ■■■시스템 유지보수 인력의 내부망 및 외부망 접속 시 할당된 IP주소로 기록될 수 있도록 시스템을 개선하시기 바랍니다.(통보)

한국수력원자력(주) 상임감사위원

통 보

제 목 세부적인 작업 내용 기록 미흡

관 련 부 서 ○○본부 회센터

조 치 부 서 ○○본부 회센터

내 용

1. 업무 개요

○○본부 회센터는 전사 정보보호 정책 수립 및 시행 총괄, 전사 개인정보 보호 정책 수립 및 시행 총괄, 정보보호 인프라 구축 및 운영 등의 업무를 담당하고 있다.

2. 관계 법령 및 판단기준

우리 회사 「정보보안업무 세부운용지침」 제52조에는 정보시스템 관리책임자는 정보시스템의 유지보수와 관련한 절차, 주기, 문서화 등과 관련한 사항을 자체 내규(또는 지침 등)에 포함하여야 하고, 예방 및 유지보수에 대한 기록 유지, 작업 수행 내용 기록 유지 등을 고려하여야 한다고 명시되어 있다.

우리 회사 “❖❖❖❖(▼▼ 보안관리 지침)” ㉠항에 따르면 사업자에게 제공된 전산망 접근기록을 확인할 수 있도록 작업 로그를 1년 이상 저장하여야 한다.

3. 세부적인 작업 내용 기록 미흡

◆◆시스템은 사내에서 발생하는 모든 문서를 효율적으로 추적·활용·관리할 수 있도록 도와주는 시스템으로서 클라우드 기반의 업무환경을 제공하여, 직원 개인이 ◆◆시스템에 자료를 생성 또는 저장할 수 있고, 권한을 부여하여 해당 자료를 공유할 수 있다.

전임자의 퇴직·휴직·보직 이동 등으로 인하여 ◆◆시스템 내 전임자 자료의 소유권(권한)을 후임자로 변경해야 할 경우, 부서 내 문서관리자가 해당 자료의 “소유권 변경”을 수행할 수 있는 기능이 있는데, 기능 사용이 익숙하지 않거나 부서 문서관리자가 부재일 경우 유지보수 인력이 대행해서 해당 작업을 수행하고 있다.

그런데 최근 1년간(2023. 11. 1.~2024. 10. 31.) ◆◆시스템 유지보수 인력의 작업 내역을 확인한 결과, “소유권 변경” 작업의 경우 “가 소유권변경되었습니다.”(♣건), “문서 소유권이 변경 되었습니다.”(♣건)와 같이 세부적인 작업 내용을 확인할 수 없는 기록이 확인되었다.

관련부서에 세부적인 작업 내용을 확인한 결과, 단일 문서 또는 폴더를 선택하여 소유권을 변경하거나, 다수의 문서 또는 폴더를 선택하여 소유권을 변경한 작업으로 확인되었는데, 보안상의 문제는 없어 보이나 유지보수 인력의 작업 내용이 세부적으로 기록될 수 있도록 개선이 필요하다.

관련부서 의견 관련부서는 감사 결과를 수용하고 문서 및 폴더의 소유권 변경 시 로그 상 작업된 파일명이 상세히 표시될 수 있도록 시스템을 수정할 예정이며, 부서 문서관리자가 직접 소유권 변경을 할 수 있도록 안내하고, 진행이 불가한 경우 작업 이력을 기록한 후 작업을 진행하겠다는 의견을 제시하였다.

조치할 사항 회센터장은 ◇◇시스템 유지보수 인력의 문서 또는 폴더의 소유권 변경 관련 세부적인 작업 내용이 기록될 수 있도록 시스템을 개선하시기 바랍니다.(통보)

한국수력원자력(주) 상임감사위원

통 보

제 목 개인정보 관련 지침서 내용 오류

관 련 부 서 ○○본부 회센터

조 치 부 서 ○○본부 회센터

내 용

1. 업무 개요

○○본부 회센터는 전사 정보보호 정책 수립 및 시행 총괄, 전사 개인정보 보호 정책 수립 및 시행 총괄, 정보보호 인프라 구축 및 운영 등의 업무를 담당하고 있다.

2. 관계 법령 및 판단기준

「개인정보의 안전성 확보조치 기준」 제8조에 따르면 개인정보처리자는 개인정보취급자의 개인정보처리시스템에 대한 접속기록을 1년(고유식별정보 또는 민감정보 처리 시 2년) 이상 보관·관리하여야 하고, 우리 회사 「개인정보의 보호와 관리에 관한 규정」 제72조에 따르면 개인정보처리시스템 운영 부서장은 개인정보취급자가 개인정보처리시스템에 접속한 기록을 1년 이상(고유식별정보 또는 민감정보 처리 시 2년) 이상 보관·관리하여야 한다.

3. 개인정보 관련 지침서 내용 오류

우리 회사는 개인정보처리시스템 사용자에게 대한 본인 확인 및 접근 권한 관리 기준을 마련하고 개인정보의 오남용 및 불법적 유출을 방지하고자 “ 관리 기준(♣♣ 지침서)”를 운영하고 있는데, 해당 지침서의 ◆항에는 “개인정보시스템에 대한 접속기록은 최소한 6개월 이상 보관한다”고 명시되어 있다.

우리 회사 “ (♣♣ 지침서)”에 명시된 개인정보시스템에 대한 접속기록 보관기간인 “6개월 이상”은 관련 규정에 명시된 “1년(고유식별정보 또는 민감정보 처리 시 2년) 이상”과 불일치하므로, 혼동 방지 및 관련 규정의 준수를 위하여 해당 지침서()의 개인정보시스템에 대한 접속기록 보관기간은 관련 규정에 명시된 보관기관으로 수정이 필요하다.

관련부서 의견 관련부서는 감사 결과를 수용하고 개인정보시스템에 대한 접속기록 보관기간이 6개월로 오작성된 “ (♣♣ 지침서)”를 조속히 개정 하겠다는 의견을 제시하였다.

조치할 사항 회센터장은 개인정보처리시스템에 대한 접속기록 보관기간을
관련 규정에 명시된 보관기간과 일치하도록 관련 지침서(☐☐☐☐☐☐)를 개정하시기
바랍니다.(통보)